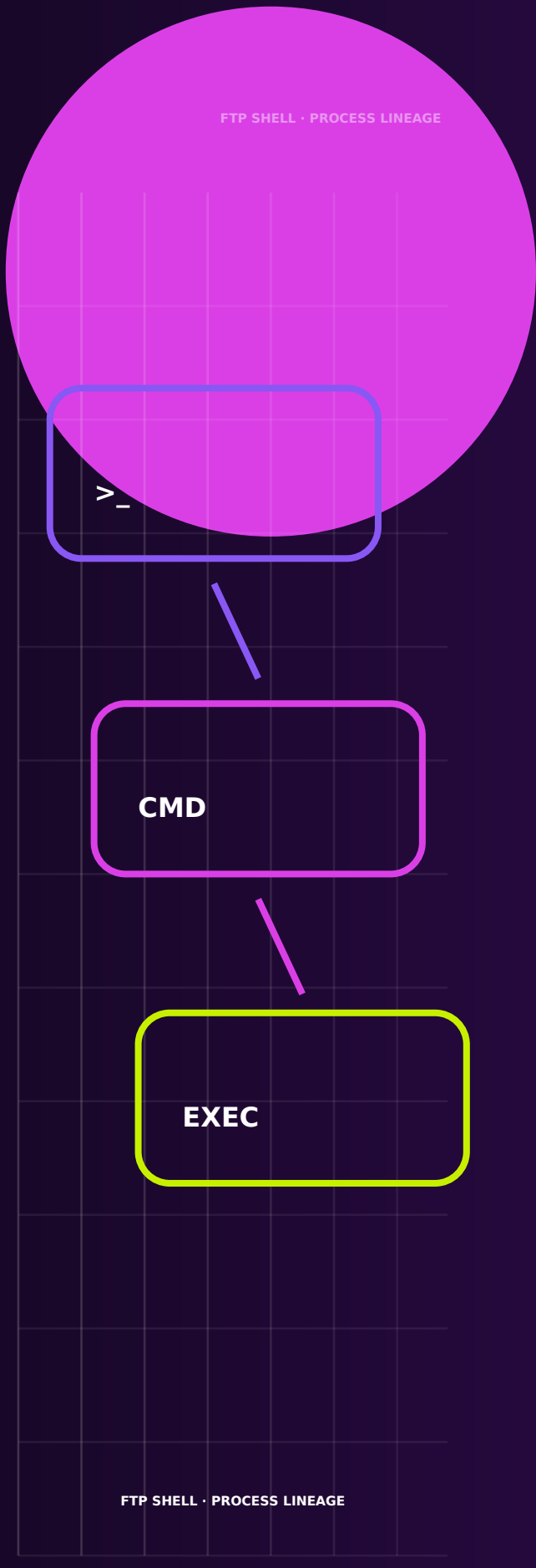
DETECTION THREAT LANDSCAPE

BITTER / PAPRAT - FTP.EXE LOCAL COMMAND SHELL ESCAPE

Defender XDR hunt for cmd.exe launched directly by the native Windows FTP client



HUNTING QUERY

CONFIDENCE: MEDIUM

REPORT TYPE
campaign

STATUS
Untested implementation sketch

PRIMARY PLATFORM
Microsoft Defender XDR

OPERATIONAL VALUE
9 / 10

01

Executive Assessment

Decision-grade summary with explicit evidence boundaries.

ASSESSMENT

DECISION

Publish as a behavioral hunting query, not an alert. Investigate direct ftp.exe-to-cmd.exe process lineage as evidence of a local FTP shell escape, and require script provenance plus adjacent endpoint activity before associating a match with BITTER, PapRAT or compromise.

SOURCE-CONFIRMED

- Only FortiGuard's LNK/ftp.exe chain is in scope. [C001]
- Chain 1 sends res.ico to cmd.exe; later scripts use scheduled tasks and curl. [C002][C003]
- Microsoft documents FTP ! and the DeviceProcessEvents fields used. [C004][C005]

ANALYST ASSESSMENT

- A direct ftp.exe-to-cmd.exe relationship avoids mutable campaign artifacts. [C006]
- A match proves process lineage only, not malicious content or the wider intrusion. [C007]
- Keep as Medium-confidence hunting until controls measure telemetry and overlap. [C009]

DETECTION ASSUMPTIONS

- Defender for Endpoint represents the FTP shell escape as ftp.exe directly starting cmd.exe. [C006]
- Required DeviceProcessEvents fields are populated on in-scope Windows endpoints. [C005][C009]

KEY FINDINGS

FINDING 1

FortiGuard Labs documented a BITTER campaign in which one infection chain used a malicious LNK, ftp.exe and the FTP ! command to pass local commands to cmd.exe. [C001][C002]

FINDING 2

The durable observable is the unusual direct process relationship ftp.exe to cmd.exe; the published scheduled-task, curl, reconnaissance and exfiltration behavior is outside this query. [C003][C006]

FINDING 3

Microsoft documents both the FTP shell escape and the Defender XDR parent-process fields, but the exact EDR lineage remains an unexecuted analytical inference requiring a controlled test. [C004][C005][C007]

EVIDENCE BOUNDARY

FortiGuard Labs does not provide exact campaign start and end dates; it reports activity over the preceding several months. The initial delivery channel and victim interaction that caused LNK execution are not disclosed. Target-environment prevalence of legitimate FTP scripts that invoke local operating-system commands is not measured. No raw Defender XDR event from the reported intrusion or retained laboratory execution was available for this analysis.

02

Threat Mechanics

Technical mechanism, observable transitions and supported scope.

ATTACK FLOW

TECHNICAL BACKGROUND

FortiGuard Labs separated the activity into three infection chains. In chain 1, a malicious LNK starts the native Windows FTP client with script content; the FTP ! facility crosses from FTP directive processing into a local command prompt. The source shows !more res.ico feeding local script content to cmd.exe, after which later commands establish scheduled-task execution, retrieve command files and perform reconnaissance or upload. The enabling condition is successful LNK execution plus the documented FTP shell-escape behavior; the original delivery vector and exact EDR lineage remain unresolved. This package detects only the proposed ftp.exe-to-cmd.exe process boundary and deliberately excludes the two PapRAT MSI chains. [C001][C002][C003][C004][C006]

1

INITIAL EXECUTION

A user or process opens a malicious LNK that invokes the native Windows FTP client with attacker-supplied script content. Observable: LNK provenance and ftp.exe command line; contextual evidence, not required by the query.

2

TRUST-BOUNDARY TRANSITION

The FTP ! command leaves FTP directive processing and runs an operating-system command locally. Observable: Expected direct child-process lineage from ftp.exe to cmd.exe; laboratory confirmation is pending.

3

COMMAND EXECUTION

cmd.exe interprets script content read from res.ico in the source-observed chain. Observable: DeviceProcessEvents child FileName cmd.exe and InitiatingProcessFileName ftp.exe.

4

FOLLOW-ON ACTIVITY

Source-observed scripts create scheduled tasks, use curl, perform host discovery and upload collected data. Observable: Scheduled-task, process, file and network evidence; enrichment only and not inferred from a query match.

03

Telemetry & Evidence Model

Minimum data contract and known visibility gaps.

DATA CONTRACT

PRIMARY PLATFORM

Microsoft Defender XDR. Return Defender XDR process events where cmd.exe is created directly by ftp.exe; use the portal time picker rather than an embedded threshold.

FIELD / TABLE	STATUS	PURPOSE
DeviceProcessEvents	**Required**	Microsoft Defender for Endpoint process-creation records for the child and initiating process.
FileName, InitiatingProcessFileName	**Required**	Evaluate the child and direct initiating-process conditions.
Timestamp, DeviceName, ReportId	**Required**	Preserve the documented compound event identity for investigation.
ProcessCommandLine, InitiatingProcessCommandLine	**Enrichment**	Preserve child and parent command context without assuming FTP script contents are present.
ProcessUniqueId, InitiatingProcessUniqueId	**Enrichment**	Retain stable process pivots for lineage validation.
DeviceId, account, path, hash, file, network and scheduled-task context	**Enrichment**	Resolve ownership and test for source-observed script, curl and persistence activity.

KNOWN VISIBILITY GAPS

The command token and FTP script contents are not guaranteed in DeviceProcessEvents The published Microsoft FTP command documentation covers legacy Windows versions No direct proof of LNK provenance, script intent, scheduled-task persistence or network outcome Target-environment prevalence is unmeasured Laboratory execution has not been performed

04

Primary Detection Logic

Native query, explicit condition evidence and match meaning.

KQL

```
// Title: BITTER / PapRAT - ftp.exe local command shell child
// Rule name: T1059.003 - ftp.exe local command shell child
// Classification: Hunting query
// Status: Untested implementation sketch
// Primary platform: Microsoft Defender XDR advanced hunting
// Telemetry: Microsoft Defender for Endpoint DeviceProcessEvents
// MITRE ATT&CK: T1059.003 - Windows Command Shell
// Purpose: Identify cmd.exe process creation with the native Windows FTP client as its direct initiating process.
// Logic: Two documented process-name equality filters; the portal time picker controls the search interval.
// Match proves: Defender XDR recorded cmd.exe with InitiatingProcessFileName represented as ftp.exe.
// Match does not prove: use of the FTP ! token, malicious script content, LNK execution, scheduled-task creation,
// PapRAT deployment, C2, reconnaissance, exfiltration, compromise, or BITTER attribution.
// False positives: authorized legacy FTP automation using !, compatibility/security testing, or lineage-quality issues.
// Limits: DeviceProcessEvents does not guarantee visibility into the FTP script token or file contents; the exact
// parent-child representation and target-environment prevalence have not been validated.
// Validation: run the controlled positive and negative tests in validation.md before any alert promotion.
// Evidence claims: C002, C004, C005, C006, C007, C008, C009

DeviceProcessEvents
| where FileName =~ "cmd.exe"
| where InitiatingProcessFileName =~ "ftp.exe"
| project
    Timestamp,
    DeviceId,
    DeviceName,
    AccountName,
    InitiatingProcessAccountName,
    FileName,
    FolderPath,
    ProcessCommandLine,
    SHA1,
    ProcessUniqueId,
    InitiatingProcessFileName,
    InitiatingProcessFolderPath,
    InitiatingProcessCommandLine,
    InitiatingProcessSHA1,
    InitiatingProcessUniqueId,
    InitiatingProcessParentFileName,
    ReportId
| order by Timestamp desc
```

WHAT A MATCH PROVES

Microsoft Defender for Endpoint recorded a cmd.exe process event whose initiating process is represented as ftp.exe.

WHAT IT DOES NOT PROVE

A match does not prove use of the FTP ! token, malicious script content, LNK execution, scheduled-task creation, PapRAT deployment, C2, reconnaissance, exfiltration, compromise or BITTER attribution.

MATURITY

Hunting query - Untested implementation sketch. Return Defender XDR process events where cmd.exe is created directly by ftp.exe; use the portal time picker rather than an embedded threshold.

05

Triage & Hunting Playbook

Evidence-preserving workflow from match to disposition.

WORKFLOW

01

Preserve the raw DeviceProcessEvents row, query version, Timestamp, DeviceId, DeviceName and ReportId.

02

Confirm the direct lineage using ProcessUniqueId and InitiatingProcessUniqueId; inspect full child and parent command lines without assuming they contain FTP script contents.

03

Recover the ftp.exe script source, LNK provenance and adjacent file events where authorized; identify whether the FTP ! command was present.

04

Validate user, device role, software owner and any approved FTP automation that intentionally runs local operating-system commands.

05

Pivot to scheduled-task, curl, file and network activity documented for chain 1, while treating each as independent corroboration.

06

Associate with BITTER or PapRAT only when campaign artifacts or independent incident evidence corroborate the process lineage.

DISPOSITION RULE

Escalate only when the evidence establishes the behavior described by the query. A match does not prove use of the FTP ! token, malicious script content, LNK execution, scheduled-task creation, PapRAT deployment, C2, reconnaissance, exfiltration, compromise or BITTER attribution.

06

False Positives & Validation

Overlap model, controlled checks and promotion gate.

QUALITY GATE

AUTHORIZED FTP AUTOMATION USING LOCAL COMMANDS

Require an accountable owner, approved script provenance, known execution schedule and expected child command.

WINDOWS FTP TRAINING OR SECURITY-CONTROL TESTING

Validate change or test records, isolated device role and a harmless command payload.

EDR PROCESS-LINEAGE OR FIELD-QUALITY ANOMALY

Inspect raw events and stable process identifiers; reject alert promotion if lineage cannot be reproduced consistently.

VALIDATION SEQUENCE

- Confirm DeviceProcessEvents coverage and population of every filtered and projected field on representative Windows endpoints.
- In an isolated authorized Windows lab, run ftp.exe with a benign script that uses ! to invoke cmd.exe and write a uniquely named harmless marker file.
- Run negative controls: FTP automation without !, cmd.exe launched by PowerShell, and an interactive FTP session that performs only transfer commands.
- Execute the query unchanged and preserve the raw positive and negative events, process tree and marker-file timeline.
- Measure historical prevalence over an approved review period and resolve every legitimate owner before considering alert logic.

SUCCESS

The controlled FTP shell escape yields one complete ftp.exe-to-cmd.exe process event, all required fields are populated, negative controls do not match and legitimate overlap can be bounded by provenance.

REJECTION

Reject the hypothesis or redesign the hunt if the shell escape does not create the expected lineage, required fields are absent, negative controls match or legitimate overlap cannot be bounded.

PROMOTION GATE

Require retained positive and negative controls, reproducible parent-child semantics, field-completeness evidence, measured prevalence and durable ownership controls before designing an alert.

07

Analyst Assessment & References

Coverage statement, open questions and source record.

FINAL

CONCLUSION

The source documents a technically coherent abuse of a built-in FTP shell escape, and the proposed parent-child primitive is more durable than campaign IOCs. Because the exact Defender XDR lineage and benign prevalence remain untested, retain this as a Medium-confidence hunt and do not infer the wider BITTER/PapRAT intrusion from a match.

MITRE ATT&CK

T1059.003

PRIMARY AND AUTHORITATIVE REFERENCES

S001 FortiGuard Labs - BITTER Expands Its Arsenal with PapRAT (2026-11-02)

hxxps://www[.]fortinet[.]com/blog/threat-research/bitter-expands-its-arsenal-with-paprat

S002 Microsoft - DeviceProcessEvents table in the advanced hunting schema (2026-08-07)

hxxps://learn[.]microsoft[.]com/en-us/defender-xdr/advanced-hunting-deviceprocessevents-table

S003 Microsoft - Ftp: ! (2016-08-31)

hxxps://learn[.]microsoft[.]com/en-us/previous-versions/windows/it-pro/windows-server-2012-r2-and-2012/ff687695(v=ws[.]11)

S004 MITRE ATT&CK - Command and Scripting Interpreter: Windows Command Shell, T1059.003 (2026-05-12)

hxxps://attack[.]mitre[.]org/techniques/T1059/003/

OPEN QUESTIONS

FortiGuard Labs does not provide exact campaign start and end dates; it reports activity over the preceding several months. The initial delivery channel and victim interaction that caused LNK execution are not disclosed. Target-environment prevalence of legitimate FTP scripts that invoke local operating-system commands is not measured. No raw Defender XDR event from the reported intrusion or retained laboratory execution was available for this analysis.

DOCUMENT CONTROL

Schema 2.0 | Layout 2.0 | Maturity hunting | Confidence Medium | No customer data | Evidence ledger required